

Versao 1.3.0
08 de Maio de 2026

Escopo: Completo (todo o monorepo)
~180 arquivos | ~45.000+ linhas analisadas

Empresa: MomAI
MomAIOS - Assistente Virtual Local-First
Confidencialidade: Para uso interno

SUMARIO

1. Resumo Executivo
2. Problemas Criticos (2)
3. Problemas de Alta Prioridade (21)
4. Problemas de Media Prioridade (29)
5. Problemas de Baixa Prioridade (7)
6. Sumario de Metricas
7. Recomendacoes

1. RESUMO EXECUTIVO

A auditoria completa do MomAIOS revelou **59 problemas** no total, sendo **2 criticos**, **21 de alta prioridade**, **29 de media prioridade** e **7 de baixa prioridade**. As areas mais problematicas sao:

- Seguranca:** Injecao de comandos via `exec()` no sistema de extensoes e launcher
- Duplicacao de codigo:** Copias quase identicas de arquivos grandes (node-core, launcher runtime, detectores de idioma)
- TypeScript sem tipo:** Uso generalizado de `any`, `@ts-ignore`, e falta de declaracoes para bridge Electron
- Performance:** Scans completos de filesystem, operacoes sincronas em hot paths, FFT em threads de audio
- Streaming SSE:** Mensagens `{done: true}` nao enviadas em abort, erros que nao interrompem fluxo
- Praticas assincronas:** Race conditions em `active_websockets`, variaveis de modulo compartilhadas sem sincronizacao

Prioridade	Quantidade	Percentual
Criticos	2	3.4%
Alta	21	35.6%
Media	29	49.2%
Baixa	7	11.9%
Total	59	100%

2. PROBLEMAS CRITICOS

Problemas com potencial de causar execucao remota de codigo, perda de dados, ou comprometimento severo da seguranca do sistema.

C1: Injecao de Comando no Launcher Skill (openItem)

Arquivo: apps/momai/scripts/skills/packaged/launcher/runtime.js:670

Categoria: Seguranca - Execucao Remota deCodigo

Impacto: Caminho nao sanitizado via exec() permite execucao de comandos arbitrarios. Caminho origina-se do LLM. Copia identica em data/extensions/launcher/runtime.js

O que afeta: Usuarios finais - comandos executados no contexto do Node Core

O que vai mudar: Substituir exec() por spawn() com array de argumentos

Ganho esperado: Eliminacao completa do vetor de injecao de comandos

Solucoes Possiveis:

- **(Recomendada)** Substituir exec() por spawn() ou execFile() com array de argumentos
- Escape rigoroso de metacaracteres shell no caminho
- Validar caminho contra lista de permissao de diretorios

C2: Injecao de Comando na Instalacao de Extensoes (extractZip)

Arquivo: apps/momai/scripts/node-core/api/routes/extensions.routes.js:86-100

Categoria: Seguranca - Execucao Remota deCodigo

Impacto: Apenas aspas simples escapadas. PowerShell executa comandos via ;, |, \$(), backticks. zipPath/destDir derivados do payload.id do cliente.

O que afeta: Usuarios que instalam extensoes

O que vai mudar: Substituir comando PowerShell por API nativa de extracao ZIP

Solucoes Possiveis:

- **(Recomendada)** Usar biblioteca JS nativa (adm-zip) para extracao sem shell
- Usar spawn('powershell', ['Expand-Archive', ...]) com array de argumentos
- Manter exec() com escape rigoroso (fragil)

3. PROBLEMAS DE ALTA PRIORIDADE (21)

H1: XSS via iframe srcdoc com allow-scripts

Arquivo: components/chat/DevHtmlRenderCard.tsx:47-50, HtmlPreviewCard.tsx:24-29

Categoria: Seguranca

Impacto: Scripts executados em iframe permitem phishing e engenharia social

Solucao Recomendada: Remover allow-scripts, usar DOMPurify, ou isolar em Worker

H2: Extension Host Worker sem Isolamento VM

Arquivo: extension-host-worker.js, registry.js:436-497

Categoria: Seguranca

Impacto: Extensoes tem acesso total a fs, child_process, network

Solucao Recomendada: Usar vm.createContext() e implementar permissoes efetivas

H3: Falta de Declaracoes de Tipo para Bridge Electron

Arquivo: 14 ocorrencias em hooks/ e services/

Categoria: Type Safety

Impacto: Bridge Electron sem tipo, erros so em runtime

Solucao Recomendada: Criar types/api.d.ts, usar type-only imports

H4: Sandbox Desabilitado sem Documentacao

Arquivo: windowManager.ts:234-249

Categoria: Seguranca

Impacto: Superficie de ataque expandida, defaults nao explicitos

Solucao Recomendada: Definir contextIsolation, nodeIntegration, webSecurity explicitamente

H5: Race Condition em active_websockets

Arquivo: app_state.py:14, voice.py:17

Categoria: Concorrencia

Impacto: list.remove() e append() concorrentes causam crash

Solucao Recomendada: Adicionar asyncio.Lock em todas as mutacoes

H6: Duas Copias do Node-Core

Arquivo: scripts/node-core/ vs apps/momai/scripts/node-core/

Categoria: Duplicacao

Impacto: APIs divergentes, endSse ausente na copia antiga

Solucao Recomendada: Remover copia desatualizada, unificar imports

H7: Duplicacao de Language Detector

Arquivo: chat-service.js:117-253 e domain/language-detector.js

Categoria: Duplicacao

Impacto: Correcoes em um arquivo nao refletem no outro

Solucao Recomendada: Unificar em unico modulo

H8: Duplicacao de Fallback Reply Logic

Arquivo: chat-service.js:255-455 e domain/prompt-builder.js

Categoria: Duplicacao

Impacto: Mesmo problema do H7

Solucao Recomendada: Unificar em unico modulo

H9: Duplicacao do Launcher Runtime (900+ linhas)

Arquivo: packaged/launcher/runtime.js e data/extensions/launcher/runtime.js

Categoria: Duplicacao

Impacto: Duas copias, fonte da verdade ambigua

Solucao Recomendada: Manter version em packaged, criar symlink

H10: Monolito _listen_loop() (178 linhas)

Arquivo: detector.py:206-384

Categoria: Manutenibilidade

Impacto: Audio, state machine, modos, cooldown, FFT em uma funcao

Solucao Recomendada: Extrair state machine e handlers separados

H11: Monolito _speech_worker() (148 linhas)

Arquivo: tts.py:315-462

Categoria: Manutenibilidade

Impacto: Streaming, resampling, fade, FFT, playback em uma funcao

Solucao Recomendada: Quebrar em funcoes menores

H12: Monolito _process_recording() (101 linhas)

Arquivo: detector.py:460-561

Categoria: Manutenibilidade

Impacto: Transcricao, filtragem em uma funcao

Solucao Recomendada: Extrair em funcoes dedicadas

H13: Monolito `_handle_transcription()` (111 linhas)

Arquivo: detector.py:634-745

Categoria: Manutenibilidade

Impacto: Keyword, cooldown, comando extraction em uma funcao

Solucao Recomendada: Extrair em funcoes dedicadas

H14: FFT na Thread de Audio (Detector)

Arquivo: detector.py:227-239

Categoria: Performance

Impacto: `np.fft.rfft()` no callback de audio causa glitches

Solucao Recomendada: Mover FFT para thread separada com queue

H15: FFT em Chunks de TTS

Arquivo: tts.py:414-438

Categoria: Performance

Impacto: `np.fft.rfft()` a cada chunk (~0.15s), *20 sem doc

Solucao Recomendada: Mover para thread separada ou reduzir frequencia

H16: Settings None Bypassa Ultra-tier

Arquivo: voice.py:183

Categoria: Seguranca

Impacto: Short-circuit permite wake word sem verificacao de tier

Solucao Recomendada: Verificar settings is not None explicitamente

H17: `process.exit()` em Falha de Bind

Arquivo: router.js:147

Categoria: Robustez

Impacto: Mata processo Electron sem cleanup

Solucao Recomendada: Propagar erro ao Electron Main, tentar porta alternativa

H18: FS Sincrono em Hot Paths (Dev Skill)

Arquivo: dev/runtime.js (1241 linhas)

Categoria: Performance

Impacto: readFileSync bloqueia event loop

Solucao Recomendada: Substituir por fs.promises assincrono

H19: Scan Completo de Filesystem no Launcher

Arquivo: launcher/runtime.js:530-539

Categoria: Performance

Impacto: Reconstroi indice varrendo todo FS

Solucao Recomendada: Aumentar TTL, usar watcher de filesystem

H20: Uso Generalizado de any em useChatHandlers

Arquivo: hooks/useChatHandlers.ts:37

Categoria: Type Safety

Impacto: ~35 branches de msg.type sem tipo

Solucao Recomendada: Definir discriminated union de WebSocketMessage

H21: SkillResponseRegistry sem Tipos

Arquivo: SkillResponseRegistry.ts:4-6

Categoria: Type Safety

Impacto: Map sem generics, registerRenderer com any

Solucao Recomendada: Usar Map com generics

4. PROBLEMAS DE MEDIA PRIORIDADE (29)

Problemas que representam violacoes de boas praticas, riscos moderados, ou oportunidades de melhoria significativas.

ID	Problema	Categoria
M1	CSP via meta tag apenas (sem HTTP header)	Seguranca
M2	Fallback !process.contextIsolated no Preload	Seguranca
M3	shell: true em killProcessOnPort	Seguranca
M4	Monkey-patching threading.Thread.start	Manutenibilidade
M5	Dados de extensao nao sanitizados no Chat Service	Seguranca
M6	SSE nao finalizado em caso de abort	Streaming
M7	SSE continua processando apos erro do LLM	Streaming
M8	Engolimento silencioso de erros (.catch(() => {}))	Error Handling
M9	API Keys em plaintext JSON no SQLite	Seguranca
M10	Race condition em stopGenerationRequested	Concorrenca
M11	Nao uso de AbortController em sendChatMessage	Performance
M12	Dependencia circular entre api.ts e ttsService.ts	Arquitetura
M13	useEffect sem useMemo em useChatActions	Performance
M14	20 regex substitutions em serie no TTS	Performance
M15	Lista blacklist recriada a cada chamada	Performance
M16	Perda de dados por debounce de 2s no Store	Data Integrity
M17	Mensagens salvas em dois locais	Duplicacao
M18	Busca O(n*m) em wake word fuzzy matching	Performance
M19	np.concatenate repetido em buffer crescente	Performance
M20	N+1 chamadas GitHub API	Performance
M21	Zero testes unitarios no Core Python	Testes
M22	StructuredResponse sem tipo, Props sem tipo	Type Safety
M23	WebSocket nao fecha se componente desmonta antes de conectar	Robustez
M24	Duplicacao de helpers de data (getTodayISO)	Duplicacao
M25	Variavel ww sem type hint	Type Safety
M26	Declarative_base legado (SQLAlchemy 1.x)	Manutenibilidade
M27	CORS regex sem ancora final	Seguranca
M28	F-strings em logger (sempre avaliados)	Performance
M29	api/deps.py definido mas nao usado	Dead Code

5. PROBLEMAS DE BAIXA PRIORIDADE (7)

ID	Problema	Detalhe
L1	IconMap duplicado	LateralBar.tsx e ExtensionsView.tsx tem mapas de icones similares
L2	Magic numbers nao documentados	Timings de animacao, * 20 no FFT, timers de reconexao
L3	useEffect sem dependencias	TitleBar.tsx:12-14 executa em todo mount
L4	getAppVersion() chamado 4+ vezes	Na inicializacao, sem cache
L5	Estilos de import inconsistentes	Relativos vs @renderer/ prefix
L6	Atributos de acessibilidade ausentes	Botoes sem aria-label, textarea sem label
L7	extractJsonObjects fragil	Falha para JSON com chaves aninhadas ou regex

6. SUMARIO DE METRICAS

Visao Geral

Item	Valor
Total de Problemas	59
Criticos	2
Alta Prioridade	21
Media Prioridade	29
Baixa Prioridade	7
Arquivos Analisados	180+
Linhas Analisadas	45.000+
Apps Auditados	5 (momai, core, node-core, skills, landing-page)

Distribuicao por Categoria

Item	Valor
Seguranca	8
Duplicacao	4
Manutenibilidade	6
Performance	6
Type Safety	5
Concorrenca	2
Stream/SSE	2
Error Handling	2
Outros	24

Distribuicao por Componente

Item	Valor
Electron Main / Preload	5
Renderer (React/TS)	13
Node Core	18
Core Python (FastAPI)	16
Skills	7

7. RECOMENDACOES

Top 5 Acoes Imediatas (Criticas)

1. Corrigir injecao de comando no Launcher (C1)

Substituir `exec()` por `spawn()` com array de argumentos no metodo `openItem()`.

2. Corrigir injecao de comando no extractZip (C2)

Substituir PowerShell por `adm-zip` para extracao de ZIP.

3. Adicionar declaracoes de tipo para window.api (H3)

Criar `types/api.d.ts` com declaracoes completas para bridge Electron.

4. Restringir sandbox de iframe (H1)

Remover `allow-scripts` e sanitizar HTML com `DOMPurify`.

5. Adicionar `asyncio.Lock` em `active_websockets` (H5)

Prevenir race condition em conexoes WebSocket concorrentes.

Top 5 Acoes de Medio Prazo

6. Eliminar copia duplicada do node-core (H6)

Remover `scripts/node-core/` desatualizado e unificar imports.

7. Refatorar monolitos do detector.py (H10, H12, H13)

Extrair state machine, handlers de transcricao em classes/funcoes separadas.

8. Mover FFT para threads separadas (H14, H15)

Evitar FFT no callback de audio em tempo real.

9. Unificar detectores de idioma e fallback replies (H7, H8)

Consolidar implementacoes duplicadas em modulos unicos.

10. Adicionar testes unitarios no Core Python (M21)

Criar `tests/` e implementar testes para servicos de voz e API.

Top 5 Acoes de Longo Prazo

11. Isolar execucao de extensoes em VM (H2)

Usar `vm.createContext()` do Node.js para contexto isolado.

12. Eliminar uso de any no sistema de chat (H20, H21)

Definir discriminated unions para WebSocket e tipos genericos.

13. Implementar AbortController no streaming (M11)

Permitir cancelamento de streams in-flight.

14. Resolver dependencia circular api.ts/ttsService.ts (M12)

Extrair tipos compartilhados para quebrar o ciclo.

15. Adicionar CSP via HTTP headers (M1)

Usar `onHeadersReceived` para headers CSP alem do meta tag.